NEXUS WORK 팀원별 작업 계획서

프로젝트 기획서의 역할 분담을 팀원별 할 일로 풀어 쓴 문서입니다. 목표는 10/23(금) 기획서 제출일까지 구축을 끝내는 것이고, 그 뒤는 실측 검증·시연 녹화·포트폴리오를 준비합니다(리허설 11/5, 본발표 11/6). 역할은 팀 역할표(A 앱·DB 하드닝=홍주형, B 네트워크=이시헌, C 탐지=김태빈, D 자동화·상황판=진혜정)를 기준으로 하고, AI 에이전트는 홍주형이 마지막에 포털에 연결하고, AI와 관련된 작업은 모두 7장에 모아 마지막 단계에서 진행합니다. 기한은 제안이라 팀에서 조정해도 됩니다.

1. 한눈에 보는 일정

날짜	해야 할 일	확인 기준
10/17(토)~10/18(일)	주소·포트·로그 형식 같은 공통 약속 정하기, 각자 환경 준비	2장의 결정 사항이 모두 정해짐
10/19(월)~10/20(화)	각자 담당 부분 구현	담당별 1차 완료 기준 충족 (mock 응답으로 시험 가능)
10/21(수)	통합 점검 1차	공격 하나가 로그 → 탐지 → n8n 대응까지 이어짐
10/22(목)	통합 점검 2차, 오탐 조정, 증거 캡처	R1 발동·해제 확인(R2~R4는 AI 연동 후), 동시 공격 시험
10/23(금)	기획서 제출, 구축 완료 점검	제출 완료, 자체 보안 점검(AI 데이터 접근·프롬프트 인젝션·세션 키 강도) 결과를 위험 목록에 반영, 남은 일 목록 정리
마지막 단계(일정은 홍주형이 연결하는 시점에 맞춰 정함)	AI 에이전트 연동(홍주형이 포털에 연결), Groq API(openai/gpt-oss-120b) 연동 확인, AI 이벤트 로그, R2~R4 탐지, AI 대응(7장)	AI 연동 후 R2~R4가 발동하고 n8n이 대응함

10/23 현재 진행 현황: 10/22에 전자결재 UI·감사로그 화면 개편, Waitress 프로덕션 전환, pfSense 경유 실 IP 복원, DB 포트 3307 통일·외부 차단을 완료했고, 같은 날 네트워크 경계(pfSense)의 n8n·Graylog·DB·Ollama 콘솔 과다 노출을 발견해 이시헌·김태빈이 방화벽 규칙으로 조치 중입니다. 10/23 오전에는 제출 전 마지막 보안 점검으로 AI 에이전트 데이터 접근 범위(양호), 프롬프트 인젝션 방어(완화된 표현에 우회 가능 — 탐지 규칙 보강 필요), 세션 서명 키 강도(테스트 도구 제약으로 중단, 재시도 필요)를 자체 점검했습니다. 아래 진혜정·김태빈·홍주형·이시헌의 작업표에서 남은 일을 확인하세요.

AI 에이전트(Groq 무료 API 연동)는 홍주형이 마지막에 붙입니다. 그 전까지 다른 담당은 AI 없이 (mock) 시험하고, AI와 관련된 작업은 7장에 모아 마지막 단계에서 진행합니다.

2. 먼저 정할 것 (10/18까지)

항목	정할 사람	내용
접속 주소·포트	홍주형, 이시헌	포털이 외부(0.0.0.0)에서 요청을 받도록 하고 포트를 확정(현재 5070). 기획서 구성도는 5070으로 맞춰 두었습니다
AI 모델·API	이시헌, 진혜정	포털 화면에서 모델을 고릅니다. 기본은 자동 선택(Groq 무료 API의 openai/gpt-oss-120b → 로컬 Ollama qwen2.5:7b → 내장 어시스턴트)이며 키는 .env에만 둡니다. Groq가 안 되면 Ollama로 내려가므로 포털 PC에서 Ollama도 켜 둡니다
로그 형식	홍주형, 김태빈	기존 이벤트 29종의 필드(시각, 이벤트, 사용자, 역할, IP, 경로, 판정, 사유)에 맞추고, AI 관련 이벤트는 7장 담당자가 추가합니다
잠금 정책	홍주형, 김태빈	포털이 5회 실패 시 15분 잠금을 건다는 점이 R1(5회 실패 후 성공)과 겹칩니다. 기획서 R1은 3회 이상 실패 후 성공 또는 잠금 발생으로 고쳐 두었습니다. 시험·강사님 계정은 보호 계정 목록(.env의 PROTECTED_USERS)에 넣어 자동 잠금 대신 세션 종료만 하고, 잠금은 사람이 승인하기로 했습니다(계정 이름은 추후 확정)
티켓 저장 위치	진혜정	4종 티켓을 어디에 기록할지(n8n 내장 표 등) 정합니다
비밀값 관리	전원	비밀번호·API 키·웹훅 주소는 .env나 n8n 자격 증명에만 두고 문서·채팅·PPT에 쓰지 않습니다
포털 접속 경로와 방화벽	홍주형, 이시헌	강사님 안내에 따라 pfSense에 포트포워딩을 열고, 포털은 pfSense를 거친 접속만 받도록 포털 PC 방화벽에서 직접 접속을 차단합니다. pfSense 출발지 주소는 이시헌이 알려 주고, 적용 전에 팀원과 강사님께 접속 주소를 알립니다
n8n 위치와 DB 접속	김태빈, 진혜정, 홍주형	n8n은 Graylog2와 같은 곳(김태빈)에서 운영합니다. 포털 DB(3307)는 n8n 장비 IP에서만 접속되게 열고, 옮긴 뒤 연결은 시험 계정 한 개로 먼저 확인합니다
공격 시연 방법	진혜정	공격은 진혜정이 Kali(맥북에서도 가능)로 pfSense 경유 주소를 통해 실행합니다. 첫 시험은 기록만 하는 시험 모드로 탐지·티켓까지 확인한 뒤 계정 대응을 켭니다

3. 진혜정 — 팀장 · 자동화·상황판(역할 D)

탐지된 공격이 자동으로 차단·알림·기록으로 이어지도록 n8n을 만들고, 화이트리스트와 출발지별 상황판을 맡으며, 모든 담당의 결과를 하나로 합칩니다.

작업	기한	완료 기준
Discord 서버·채널을 만들고 웹훅 준비	10/18	n8n에서 보낸 테스트 메시지가 Discord에 도착
n8n 구동(Docker)과 Graylog Webhook 수신 설정	10/19	Graylog 시험 알림이 n8n 실행 기록에 남음
대응 워크플로: 계정 잠금, 강제 로그아웃, 경보	10/20	시험 입력 하나로 DB 열이 바뀌고 포털이 바로 반영
해제 절차와 4종 티켓(침해 인시던트, 차단 조치, 이상 징후 경보, 오탐·해제 요청)	10/21	같은 공격 팀의 이벤트가 한 티켓에 모이고, 해제하면 정상으로 복구
화이트리스트(팀원·강사님 IP)와 차단 해제 절차	10/21	정상 사용자가 차단되지 않고, 해제 후 복구됨
통합 점검 주관(1차 10/21, 2차 10/22)	10/21~10/22	공격 하나가 탐지·대응·티켓·알림까지 이어짐
출발지(공격 팀)별 상황판: 티켓·차단·해제 현황을 팀별로 한 화면에 모아 보기	10/22	동시 공격 시험 때 공격 팀별 상태가 구분되어 보임
기획서 최종 수정, 구상도 정리, 제출	10/22~10/23	10/23 제출 완료
n8n 이전 안내와 보호 계정 목록(김태빈 자리 n8n에서도 같은 대응이 동작하도록)	10/21	옮긴 n8n에서 시험 알림 13건이 기대한 티켓·대응으로 분류되고, 시험 계정 1개로 잠금·해제가 됨
공격 시연 실행(Kali, 맥북 가능): pfSense 경유로 5단계 공격	10/21~10/22	포털 로그에 공격자 출발지가 남고 탐지·대응·티켓으로 이어짐
AI 연동 후 대응: AI Tool 제한과 내부 API 토큰 폐기(Should)를 n8n에 연결하고 시험	마지막 단계	n8n에서 열을 바꾸면 다음 AI 요청부터 제한되고, 토큰 폐기 후 내부 API 호출이 거부됨

- 받아야 할 것: 홍주형의 n8n 전용 DB 계정(대응에 쓰는 열만 수정 가능), 김태빈의 규칙별 Webhook 필드. AI 제한 열 이름은 AI 연동 단계(마지막)에 받습니다
- 넘겨줄 것: 티켓·Discord 알림 형식을 팀에 공유

4. 홍주형 — 부팀장 · 웹·DB 하드닝(역할 A)

이미 만든 포털을 외부에서 시험할 수 있게 열고, 웹 코드와 DB의 방어를 단단히 하며, AI 에이전트를 마지막에 포털에 연결하는 일(7장)과 그에 필요한 연결 지점 설명 정리를 맡습니다.

작업	기한	완료 기준
포털 외부 접속 설정(0.0.0.0 바인딩, 포트 확정)과 기밀 문서에 식별용 가짜 비밀 문구·실습용 토큰 넣기	10/18	이시헌 장비에서 포털 접속, 기밀 문서에 시험용 문구와 토큰이 있음
게시판·문서함 코드 방어 점검: 입력 검증, 쿼리 파라미터화, 업로드(확장자·크기·저장 위치)와 인증 제한	10/19	스크립트·SQL 조각·위험한 파일명을 넣어도 거부되거나 무해하게 처리됨
관리자 경로 보호: 관리자 화면·기능에 역할 검사	10/19	일반 계정이 관리자 경로에 접근하면 거부되고 로그가 남음
DB 최소권한 점검과 n8n 전용 DB 계정(대응용 열만 수정, 기밀 테이블은 읽기 전용), 대응용 열 추가(AI 제한 열은 AI 연동 단계에서)	10/20	n8n 계정으로 대응 열만 바뀌고 그 외 수정은 거부됨
포털 PC 방화벽: 포털(5070)은 pfSense 출발지만 허용해 직접 접속 차단, DB(3307)는 n8n 장비 IP만 허용	10/21	직접 주소는 막히고 pfSense 경유만 접속되며, n8n 장비에서만 DB에 접속됨
보안 로그 점검: 출발지 IP가 정확히 남는지 확인하고 같은 이벤트를 GELF(12201)로도 전송(파일 로그는 유지)	10/20	security.jsonl과 Graylog에 같은 이벤트가 도착
시험 계정 준비: 정상 계정, 약한 비밀번호 시험 계정(R1 재현용), 잠금 해제 방법	10/20	잠금과 해제를 반복해서 시험할 수 있음
통합 점검 때 포털 문제 수정	10/21~10/22	점검에서 나온 포털 문제가 당일 수정됨
포털 로그 전송 주소(NEXUS_GELF_HOST)를 Graylog2가 있는 곳으로 맞추기	10/21	포털 로그인 실패 이벤트가 Graylog2에서 검색됨
AI 연결 지점 설명 정리: CHAT_RESPONDER, 문서 읽기 함수, 보안 로그 함수의 위치와 사용법	마지막 단계	7장 담당자가 설명만 보고 AI 코드를 붙일 수 있음

- 받아야 할 것: 김태빈이 탐지에 필요하다고 요청하는 로그 필드, 진혜정이 정하는 n8n이 바꿀 열 목록
- 넘겨줄 것: 포털 주소·포트, 바뀐 DB 열과 n8n DB 계정 설명을 팀에 전달

5. 김태빈 — 탐지(역할 C)

포털 로그와 파일 변경을 모아 공격을 잡아내고, 공격 팀별로 구분해 n8n에 넘깁니다.

작업	기한	완료 기준
Wazuh manager·포털 agent 연결, 문서함·업로드 폴더 FIM	10/19	문서함·업로드 폴더의 파일 변경이 Wazuh에서 보임
Graylog 입력 설정(포털 GELF 12201, Wazuh syslog 5140)과 필드 추출(이벤트, 사용자, 역할, IP, 판정)	10/20	Graylog에서 필드로 검색 가능
규칙 R1·R5~R10 구현과 n8n Webhook 연결(R2~R4·R11·R12는 AI 연동 후, 7장)	10/21	각 규칙이 시험 입력에 발동하고 n8n이 받음
Graylog2·n8n 운영: 진혜정의 n8n 워크플로를 가져와 Graylog 알림을 n8n 주소로 연결(토큰 헤더, 환경변수, 포털 DB 연결은 이전 안내 문서 참고)	10/21	Graylog 시험 알림이 n8n에 도착해 티켓과 Discord 알림까지 이어짐
포털 로그가 Graylog에 도착하는지 확인(포털의 GELF 전송 주소를 Graylog 위치에 맞춤)	10/21	포털 로그인 실패 이벤트가 Graylog에서 검색됨
출발지(IP)별 구분: 같은 IP의 이벤트를 묶어 티켓 단위로 전달	10/21	공격 두 곳을 동시에 보내면 따로 처리됨
오탐 조정: 정상 사용(로그인, 문서 열람, 요약) 기록으로 임계값 확인	10/22	정상 사용에서 규칙이 발동하지 않음
Wazuh 범용 탐지 룰(무차별 대입, 비정상 요청 등) 추가(선택)	10/22	Kali 공격 한 번에 범용 룰이 발동함
탐지 화면·규칙 설정 캡처	10/22	포트폴리오용 증거 확보

- R1 주의: 포털이 5회 실패에 잠그므로 "5회 실패 후 성공"은 일어나지 않습니다. 기획서 R1은 3회 이상 실패 후 성공 또는 잠금 발생으로 고쳐 두었으니 이 기준으로 구현하고, 임계값은 시험하며 조정합니다.
- 받아야 할 것: 홍주형의 보안 로그 이벤트 목록(AI 이벤트는 7장 담당자가 추가), 이시헌의 pfSense 로그 전송 설정(선택)
- 넘겨줄 것: 규칙별 Webhook 필드를 진혜정에게 전달

6. 이시헌 — 네트워크(역할 B)

장비들이 서로 통신하게 하고, 방화벽(pfSense)을 설정하며, 공격을 반복 재현할 수 있는 도구를 만듭니다.

작업	기한	완료 기준
장비 간 통신표(IP·포트)와 연결 시험: 포털, Graylog, Wazuh, n8n	10/18	표의 모든 연결이 ping·포트 확인을 통과
pfSense 규칙: 공격망에서 포털만 허용, 강사님 안내에 따른 포트포워딩, 로그를 Graylog로 전송(선택)	10/19	Kali에서 포털 접속 가능, 로그 전송을 했다면 방화벽 로그가 Graylog에 도착
인라인 차단 연동: n8n이 호출하면 pfSense에서 공격 IP를 차단하고, 해제하면 복구(선택)	10/21	시험 IP가 차단되고 해제하면 다시 접속됨
팀원·강사님 IP 목록을 진혜정에게 전달하고, 차단 대상에서 제외되는지 확인	10/21	정상 IP는 차단되지 않음
pfSense 경유 접속 정리: 실제 공격자 IP가 포털 로그에 남는 방법(X-Forwarded-For 또는 pfSense 직접 노출)과 포털에 보낼 출발지 주소를 홍주형에게 전달	10/21	공격 한 건의 출발지가 포털 로그에서 공격 PC로 보이고, 포털 직접 접속은 막히고 경유만 됨
Kali 공격 재현 스크립트(5단계 체인)와 동시 실행	10/20~10/22	같은 공격을 반복 재현하고, 여러 세션을 동시에 실행할 수 있음
장비 구성도·설정 화면 캡처	10/22	포트폴리오용 증거 확보

- 받아야 할 것: 홍주형의 포털 주소·포트, 진혜정의 n8n 주소
- 넘겨줄 것: 통신표와 공격 스크립트 사용법을 팀 전체에 공유

7. AI 에이전트 연동 (마지막 단계)

AI 에이전트는 홍주형이 마지막에 포털에 연결합니다. AI와 관련된 작업(로컬 LLM, AI 이벤트 로그, 게이트웨이, n8n의 AI 대응, 규칙 R2~R4)은 모두 이 장에 모아 마지막 단계에서 진행하고, 그 전까지 다른 담당은 AI 없이 시험합니다. 로컬 LLM 작업은 이시헌·김태빈 중 먼저 끝낸 사람이 가져가며, 시작 전에 두 사람이 나눌 범위를 정해 팀 채팅에 알립니다. 포털 코드를 고쳐야 하는 작업은 홍주형이 정리해 준 연결 지점에 붙이고, 브랜치를 나눠 합칩니다. 일정은 홍주형이 연결하는 시점에 맞춰 팀에서 정합니다.

작업	우선 담당	기한	완료 기준
Groq API(openai/gpt-oss-120b) 시험(Tool 호출 안정성, 응답 속도, 호출 한도)와 자동 선택의 대체 순서(Groq → Ollama → 내장) 시험	이시헌	마지막 단계	포털에서 응답이 오고 속도·한도가 시연에 쓸 만한지 판단. 안 되면 Ollama로 전환

작업	우선 담당	기한	완료 기준
응답 생성부를 mock으로 먼저 제공하고 Groq 연동(GROQ_API_KEY·GROQ_MODEL 환경변수)	먼저 끝낸 사람	마지막 단계	mock과 실제 모델 전환이 환경변수 하나로 가능
AI 제한 열을 읽어 다음 요청부터 AI 사용을 제한	먼저 끝낸 사람	마지막 단계	n8n에서 열을 바꾸면 다음 요청부터 AI가 제한됨
내부 API 만들기: 토큰 검사, 실습용 FLAG 반환, 호출 로그(토큰·출발지 IP·경로)	먼저 끝낸 사람	마지막 단계	토큰으로 호출하면 FLAG가 오고, 로그에 출발지 IP가 남음
AI가 읽는 문서에 게시글·첨부 포함(간접 인젝션 경로)	먼저 끝낸 사람	마지막 단계	게시글에 숨긴 지시문이 요약 요청 때 AI 입력에 들어감
보안 로그에 AI 이벤트 추가: 대화(원문 제외), 인젝션 패턴 탐지, Tool 호출, Tool 거부	김태빈	마지막 단계	이벤트가 정해진 필드 형식으로 기록되고 Graylog에도 도착
게이트웨이 2계층(요청자 권한 검사, Tool 정책)과 방어 전/후 전환(DEFENSE_MODE, AI 계층만)	먼저 끝낸 사람	마지막 단계	방어를 끄면 기밀 열람이 성공하고, 켜면 거부되며 로그가 남음
Tool 호출 JSON 재생 시험 스크립트	먼저 끝낸 사람	마지막 단계	LLM 없이 게이트웨이 방어를 시험할 수 있음
AI 에이전트를 포털에 연결(연결 지점 설명 정리 포함, Groq 무료 API 사용, 10/20에 포털에서 쓸 수 있게 됨)	홍주형	마지막 단계	포털에서 AI 응답이 오고, 위 작업들이 이 연결 위에서 시험됨
AI 관련 규칙(R2~R4) 구현과 n8n Webhook 연결	김태빈	마지막 단계	각 규칙이 AI 시험 입력에 발동하고 n8n이 받음
AI Tool 제한과 내부 API 토큰 폐기(Should)를 n8n 대응에 연결	진혜정	마지막 단계	n8n에서 열을 바꾸면 다음 AI 요청부터 제한되고, 토큰 폐기 후 내부 API 호출이 거부됨

- 받아야 할 것: 홍주형의 AI 연결 지점 설명과 DB 열(AI 제한 열), 진혜정이 정하는 n8n 대응 방식
- 넘겨줄 것: AI 이벤트 목록(이름·필드)을 홍주형·진혜정·김태빈에게 전달

8. 함께 지킬 것

- 비밀번호·API 키·웹훅 주소·토큰은 문서에 쓰지 않습니다.
- IP 차단·계정 잠금처럼 영향이 큰 대응은 해제 방법부터 만들고 시험합니다.
- 시험할 때 화면을 바로 캡처해 둡니다. 나중에 다시 재현하기 어렵습니다.
- 막히면 반나절 안에 팀 채팅에 공유합니다.

- 일정이 밀리면 기획서 4.4의 구현 범위에서 선택(Could) 항목부터 줄입니다.

9. AI-XDR 하이브리드 관제 확장 작업 계획

홍주형이 작성한 "NEXUS 차세대 AI-XDR 아키텍처 및 하이브리드 자동대응 기획안"을 팀 프로젝트에 추가로 반영합니다. 기존 룰셋(R1~R12) 탐지에 AI 심층 판정과 시간대별(주간 반자동/야간 완전자동) 대응을 더해 개념을 확장합니다. 진혜정은 이 확장에서 n8n·Graylog 파이프라인 구축에 김태빈을 직접 지원합니다(기존 역할 D 자동화·상황판 역할을 이 축에서 이어감). 통합 테스트는 리허설(11/5) 전까지 마칩니다.

9.1 김태빈 — 보안 관제(Wazuh·Graylog·n8n AI 판정)

작업	기한	완료 기준
Graylog `AI_TRIAGE_QUEUE` 스트림 구성 (R1~R12 + 디코이 이벤트 선별)	10/27	의심 이벤트가 스트림에 실시간으로 쌓임
n8n 이벤트 집계 노드(3분 주기, src_ip 기준 그룹화) 구축	10/28	동일 IP 반복 시도가 하나의 집계 JSON으로 묶임
AI 심층 판정 노드(Groq/Ollama 호출, JSON 응답 강제) 연결	10/29	테스트 이벤트 전송 시 threat_score·verdict가 정상 반환
Time-Gate 함수 노드(KST 08~20시 분기) 작성	10/30	같은 이벤트를 시각만 바꿔 재생해도 모드가 올바르게 분기
주간 Discord 승인 카드 + 야간 자동 집행(80점 이상) 분기 완성	11/2	주간은 승인 클릭 후 집행, 야간은 즉시 집행되는 것을 각각 확인

9.2 이시헌 — pfSense·네트워크

작업	기한	완료 기준
Remote Syslog를 192.168.3.15:514로 포워딩 설정	10/27	방화벽·HAProxy 로그가 관제 서버에 실시간 도착
`XDR_BLOCKED_IPS` URL Table Alias 구축 및 포털 피드 연동	10/28	포털 차단 목록 갱신이 1분 내 Alias에 반영
WAN 최상단 Quick Drop 규칙(Alias 소스, 로그 기록) 적용	10/29	테스트 IP 등록 후 해당 IP 트래픽이 즉시 drop·로그 기록
Inter-VLAN 허용·예외 정책(관리자 IP 영구 화이트리스트) 재점검	10/30	팀원·강사님 IP가 차단 테스트 중에도 통신 유지

9.3 홍주형 — 포털·REST API

작업	기한	완료 기준
`/internal/api/v1/ip-block`, `/blocked-ips` 응답 포맷(txt+token) 최종 점검	10/27	pfSense Alias가 포털 피드를 정상 파싱
화이트리스트 원천 차단 방지 로직 재확인(루프백·팀원 IP)	10/28	화이트리스트 IP로 차단 API 호출 시 거부됨
`/admin/audit` 대시보드에 threat_score·verdict 배지 표출	10/31	AI 판정 결과가 대시보드에 실시간 표시
n8n↔pfSense↔포털 E2E 자동화 테스트(차단→드롭 확인→만료 후 해제) pytest 작성	11/2	테스트 스위트 통과

9.4 진혜정 — n8n·Graylog 구축 지원(김태빈과 공동)

작업	기한	완료 기준
Graylog Stream/Pipeline Rule 초안 작성 보조 및 R1~R12+디코이 조건 정리	10/27	룰 조건표가 김태빈과 합의되어 스트림에 반영
n8n 워크플로우 청사진(집계→AI 호출→Time-Gate→분기 대응) 공동 설계	10/29	워크플로우 초안이 김태빈 환경에 임포트되어 동작
AI 프롬프트·JSON 스키마(threat_score, verdict, recommended_actions) 설계 및 테스트 케이스 작성	10/30	샘플 이벤트 10건에 대해 판정 결과가 기대값과 일치
주간·야간 대응 시나리오 통합 테스트 주관	11/2	같은 공격을 낮/밤 설정으로 재생해 반자동·완전자동 분기가 각각 올바르게 동작